Tapşırıq Təsviri:

1. SQL Injection Bu tapşırıqda məqsəd Blind SQL Injection (Kor SQL İnjeksiya) zəifliyindən istifadə edərək gizli flaqı tapmaqdır. Sizə verilmiş back-end tətbiqi birbaşa SQL sorğularını yoxlamır və bu, zərərli kod daxil etməyə imkan verir. Həll Addımları Tapşırığı həll etmək üçün aşağıdakı addımları izləməlisiniz: 1. Tapşırıq Mühitinə Giriş Öncəliklə, tapşırıq mühitinə daxil olun. Sizə verilən "Tapşırıq Mühitini Aç" düyməsinə klikləyin. Bu düymə sizi Flask back-end tətbiqinin işlədiyi hədəf URL-ə yönləndirəcək.

2. Zəifliyi Aşkarlamaq
  Hədəf URL /products endpoint-inə malikdir. Bu endpoint category adlı bir parametri qəbul edir. Normalda, bu, məhsulları kateqoriyaya görə axtarmaq üçün istifadə olunur. Məsələn: http://hədəf-url/products?category=elektronika Bu sorğu "elektronika" kateqoriyasındakı məhsulları geri qaytarır. Lakin, siz bu parametrin zəif olduğunu yoxlamalısınız. category parametrində eval() funksiyasından istifadə edildiyi üçün, siz ora birbaşa Python kodu daxil edərək onu işə sala bilərsiniz.

3. Blind SQL Injection Metodunu Anlamaq Tapşırığın əsas məqsədi flaqı tək-tək hərflərə ayıraraq tapmaqdır. Back-end, sorğunuz doğru olduqda müsbət cavab ("Məhsullar tapıldı!") və səhv olduqda mənfi cavab ("Məhsul tapılmadı.") qaytarır. Siz bu iki fərqli cavabdan istifadə edərək flaqın hər bir simvolunu müəyyən etməlisiniz. Bu prosesə "Blind SQL Injection" deyilir, çünki verilənlər bazasından birbaşa məlumat almırsınız, yalnız sorğunuzun doğru və ya səhv olmasından asılı olaraq verilən cavablara əsaslanırsınız.

4. Flaqın Uzunluğunu Tapmaq İlk addım flaqın uzunluğunu təxmin etməkdir. Bunun üçün len() funksiyasından istifadə edə bilərsiniz. Nümunə sorğu: http://hədəf-url/products?category=len(FLAG)>10 Əgər cavab "Məhsullar tapıldı!" olarsa, deməli flaqın uzunluğu 10-dan böyükdür. Əgər cavab "Məhsul tapılmadı." olarsa, deməli flaqın uzunluğu 10-dan kiçik və ya 10-a bərabərdir. Bu şəkildə ikili axtarış (binary search) metodu ilə flaqın dəqiq uzunluğunu tapa bilərsiniz.

5. Flaqın Hər Bir Simvolunu Çıxarmaq Flaqın uzunluğunu tapdıqdan sonra, hər bir simvolu bir-bir tapmaq üçün substring() və ya Python-da FLAG[indeks] metodundan istifadə edə bilərsiniz. Nümunə sorğu: http://hədəf-url/products?category=FLAG[0]=='C' Əgər cavab "Məhsullar tapıldı!" olarsa, deməli flaqın ilk hərfi C-dir. Əgər cavab "Məhsul tapılmadı." olarsa, deməli flaqın ilk hərfi C deyil. Bu prosesi bütün hərflər üçün təkrarlamalısınız. Hər hərfi tapdıqdan sonra, növbəti hərfi yoxlamağa keçin.

6. Terminaldan İstifadə Həll prosesini daha rahat etmək üçün "Konsol" tabını istifadə edə bilərsiniz. Burada get əmri ilə yuxarıdakı sorğuları asanlıqla göndərib cavabı yoxlaya bilərsiniz. Nümunə terminal əmri: get http://hədəf-url/products?category=len(FLAG)>20

7. Flaqı Təqdim Etmək Bütün simvolları bir-bir tapdıqdan sonra, flaqı tam olaraq əldə edəcəksiniz (məsələn, CTF{blinds_are_awesome}). Bu flaqı "Flasqı Təqdim Et" sahəsinə daxil edin və Göndər düyməsinə klikləyin. Əgər flaq düzgündürsə, siz qalib olacaqsınız! Bu tapşırıq, kiber təhlükəsizlik sahəsindəki ən geniş yayılmış zəifliklərdən biri olan Blind SQL Injection barədə biliklərinizi yoxlamaq və inkişaf etdirmək üçün əla fürsətdir.

Uğurlar!